

Cover Page

Lab 3	Planning & Scoping a Penetration Test
Duration	2 hours

Module	Professional Penetration Testing
Instructor	Phillip Fitzpatrick

Student Name	Danyil Tymchuk	Student ID	B00167321
--------------	----------------	------------	-----------

Date	16/02/2026	Submission Date	23/02/2026
------	------------	-----------------	------------

Table of Contents

Table of Contents	2
University Declaration & Use of AI	3
Scenario	4
Worksheet A — Scope Definition	5
Worksheet B — Rules of Engagement (RoE)	9
Worksheet C — Methodology Selection & Justification	12
Worksheet D — Mini Scoping Report	14

University Declaration & Use of AI

University Declaration

I confirm that this submission is my own work, except where clearly indicated. I have acknowledged all sources used. I understand the university's policies on academic integrity and plagiarism.

Use of AI Tools Declaration

I used AI-assisted support to help draft and structure the penetration testing scoping and RoE documentations. All content was reviewed, edited, and validated by me to ensure it matches the lab scenario and learning outcomes. No confidential or real client data was used.

Signed: Danyil Tymchuk

Date: 16/02/2026

Scenario

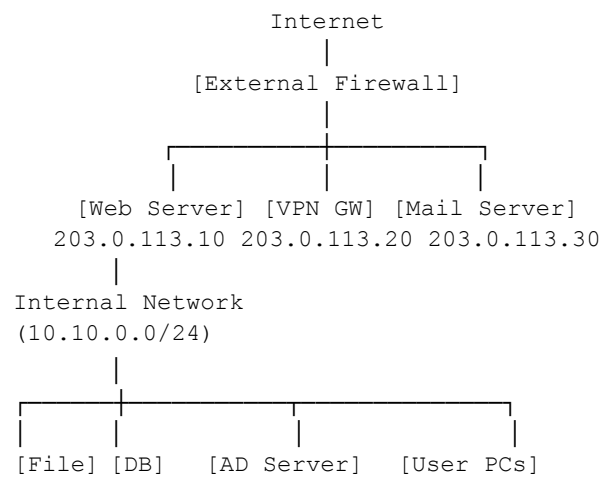
ACME Health Systems

ACME Health Systems is a mid-sized medical services provider operating multiple clinics. They process personal and sensitive data (patient demographics, appointment details, and basic clinical notes). ACME requests an external and limited internal penetration test to prepare for an upcoming audit. GDPR applies. No service disruption is permitted Monday–Friday, 08:00– 18:00.

Stakeholders

- IT Manager (primary contact): Sarah Whitaker
- Compliance Officer: Daniel Chu
- CEO (signs approvals): Marissa Henley

High-Level Network Diagram



Asset Inventory

Asset	Location	Sensitivity	Notes
Public Web Server	DMZ	Medium	Hosts patient portal
VPN Gateway	DMZ	High	Remote staff access
Mail Server	DMZ	Medium	Staff email
Active Directory	Internal	High	Domain services
File Server	Internal	High	Sensitive documents
Database Server	Internal	High	Patient data
45 User PCs	Internal	Low	Windows 10 endpoints

Worksheet A — Scope Definition

Objective

In Scope (systems/activities)

External (Internet-facing)

Internal (limited, credentialed where possible)

Out of Scope (with rationale)

Test Types (included/excluded)

Constraints (time, tools, SLAs)

Time Windows

Assumptions

Dependencies

Objective

Conduct an external penetration test with a limited internal component for ACME Health Systems to support audit readiness under GDPR, identifying exploitable security weaknesses and providing prioritized remediation guidance, without causing service disruption during business hours.

In Scope (systems/activities)

External (Internet-facing)

Scope	Test focus
Public Web Server – 203.0.113.10 (patient portal host)	web application + server exposure (safe testing only)
VPN Gateway – 203.0.113.20 (remote staff access)	authentication, configuration exposure, VPN service hardening
Mail Server – 203.0.113.30 (staff email)	mail service exposure, misconfigurations, open relays, TLS posture
Public IP space enumeration limited to: 203.0.113.10/32, 203.0.113.20/32, 203.0.113.30/3	only identify exposed ports/services and confirm ownership of these hosts

Internal (limited, credentialed where possible)

Scope	Test focus
Active Directory Server – 10.10.0.0/24	credentialed configuration review, AD security posture checks (non-destructive)
File Server – 203.0.113.20 (remote staff access)	access control review, share permissions sampling, sensitive-data exposure checks
Mail Server – 203.0.113.30 (staff email)	mail service exposure, misconfigurations, open relays, TLS posture
A small sample of User PCs (e.g., 3–5 endpoints) <i>only if explicitly approved</i>	configuration posture checks (AV, patching, local admin) — no malware simulation

Out of Scope (with rationale)

Out of Scope	Reason
Database Server exploitation/stress testing	high availability and patient-care risk; potential service disruption
Any testing Monday–Friday 08:00–18:00 that may degrade service	business constraint
Physical or human-targeted testing	not authorized by scenario
45 User PCs (full estate)	limited internal scope; sampling only with approval to reduce impact

Test Types (included/excluded)

Included

- Reconnaissance and enumeration (safe rate limits)
- Vulnerability identification and validation (non-destructive)
- Controlled exploitation only where necessary to prove impact
- Credentialed internal checks (preferred for AD/file server)
- Web application testing aligned to patient portal critical risks (auth, session, input validation)

Excluded

- Denial-of-Service (DoS/DDoS), stress/load testing
- Destructive testing (wiping, encryption, ransomware simulation)
- Social engineering (phishing/vishing), physical security testing
- Testing of third-party SaaS not owned/operated by ACME
- Bulk extraction of patient records or mass data exfiltration (GDPR/minimization)

Constraints (time, tools, SLAs)

- No service disruption permitted Monday–Friday, 08:00–18:00
- Testing windows must avoid peak hours; use low-impact scan profiles
- Rate limiting for scanners; avoid aggressive scripts/exploits by default
- Potential denial-of-service from aggressive scanning – plan safe configurations
- All findings must be reproducible with minimal risk
- Change management: Notify ACME before testing high-risk components
- Legal: Ensure signed authorisation before any testing
- GDPR requirements: minimize personal data collection, secure storage, defined retention/deletion

Time Windows

Primary testing windows (approved execution):

- Weekdays: 18:00–08:00 (local time)
- Weekends: 08:00–18:00 (or any time agreed)

Restricted window (only non-intrusive actions):

- Monday–Friday 08:00–18:00:
 - Allowed: planning calls, scope confirmation, documentation, passive OSINT, review of already-collected scan results, report writing
 - Avoid: active scanning that could impact services, any exploitation, any credential attacks

Emergency/exception window (by explicit written approval only):

- Any testing during Mon–Fri 08:00–18:00 that involves active scanning/exploitation must be:
 - specifically approved in advance by the IT Manager, and
 - run with “safe mode” configurations (rate-limits, narrow targets), and
 - have a defined rollback/stop plan

Assumptions

- Written authorization will be provided and signed by CEO before testing starts
- ACME provides:
 - IP addresses (confirmed), test accounts (for portal/VPN if needed), and internal VPN access for “limited internal” scope
 - A point of contact available for escalation during test windows
- Logging/monitoring may be active; ACME security team will whitelist tester IPs if required
- Testing team will not be held liable for issues caused by undisclosed fragile systems (subject to RoE)

Dependencies

Approvals & governance

- Signed Authorisation to Test (CEO: Marissa Henley) before any active testing
- RoE acknowledgement from:
 - IT Manager (Sarah Whitaker)
 - Compliance Officer (Daniel Chu)

Access & environment prerequisites

- Confirmation of in-scope IPs: 203.0.113.10, 203.0.113.20, 203.0.113.30
- Tester source IP(s) provided to ACME for allowlisting/monitoring baselines (if needed)
- Internal access method for limited internal testing (one of):
 - VPN account for testers, or
 - a dedicated jump box/bastion inside 10.10.0.0/24, or
 - escorted internal network access session

Credentials / accounts (preferred to minimize disruption)

- Test accounts for:
 - Patient portal (standard user + admin/clinical role if applicable)
 - VPN (standard remote staff account)
- For internal checks:
 - A domain user account for credentialed assessment
 - A read-only admin / audit account for configuration review (where appropriate)

Operational coordination

- Named on-call contact during test windows (primary + backup)
- Change-management alignment: ACME to notify testers of:
 - planned maintenance windows
 - deployments/patching affecting web/VPN/mail
- Agreement on what constitutes “service disruption” and what thresholds trigger a stop (e.g., CPU saturation, user-impacting latency, dropped VPN sessions)

Monitoring & evidence handling

- Confirmation whether ACME IDS/IPS/WAF is enabled and whether any rules will block scanning
- Agreement on log retention and whether ACME wants a list of tester IPs/User-Agents for correlation
- Secure channel for exchanging artifacts (encrypted email/SFTP/secure portal)

Safety constraints

- Confirmation of:
 - account lockout policies (to avoid accidental lockouts)
 - rate limits for portal/VPN authentication endpoints
 - any fragile/legacy services that must not be scanned

Worksheet B — Rules of Engagement (RoE)

Overview & Purpose
Authorisation (signed by)
Points of Contact (primary/secondary)
Test Schedule & Windows
Allowed Activities & Tools
Prohibited Activities
Communication & Escalation Plan
Service Degradation / Incident Handling
Logging & Monitoring Expectations
Data Handling & GDPR (retention/deletion)
Deliverables & Reporting

Overview & Purpose

Define safe, authorized, and auditable rules for conducting an external + limited internal penetration test against ACME Health Systems, ensuring operational continuity and GDPR-aligned handling of sensitive data.

Authorisation (signed by)

- **Marissa Henley (CEO)** — final approval/sign-off (required before any testing)
- Acknowledged by:
 - **Sarah Whitaker (IT Manager)** — primary operational contact
 - **Daniel Chu (Compliance Officer)** — GDPR/compliance oversight

Points of Contact (primary/secondary)

- Primary: **Sarah Whitaker (IT Manager)**
- Secondary: **Daniel Chu (Compliance Officer)**
- Executive approver: **Marissa Henley (CEO)**

Test Schedule & Windows

Preferred testing windows:

- Weekdays 18:00–08:00 (overnight)
- Weekends (if permitted)

Prohibited window:

- Monday–Friday 08:00–18:00 for any activity that could degrade services

Confirmation required before:

- Any exploitation attempt
- Any configuration change request (if needed for validation)

Allowed Activities & Tools

- Passive recon (OSINT limited to ACME-owned assets)
- Active scanning with safe settings (rate-limited)
- Manual verification of vulnerabilities
- Auth testing (brute force not allowed unless explicitly approved with thresholds)
- Credentialed checks for AD/File Server (preferred)
- Tools allowed (examples): Nmap (safe profiles), OWASP ZAP/Burp for web testing, secure configuration checklists, AD assessment tooling in read-only mode where possible

Prohibited Activities

- DoS/DDoS, stress testing, aggressive fuzzing likely to impact availability
- Password spraying/brute force against VPN/mail/portal without explicit written approval and lockout-safe plan
- Data destruction, persistence, lateral movement beyond agreed targets
- Social engineering, phishing, physical intrusion
- Exploitation that writes to disk or alters system state unless explicitly approved and controlled

Communication & Escalation Plan

- **Start-of-window notification** to Sarah Whitaker
- Immediate escalation if:
 - Service degradation observed
 - Unexpected sensitive data exposure occurs
 - High-risk vulnerability discovered requiring urgent mitigation
- Escalation path:
 - 1) Sarah Whitaker
 - 2) Daniel Chu
 - 3) Marissa Henley (if business decision needed)

Service Degradation / Incident Handling

- If monitoring indicates instability or ACME reports issues:
 - **Stop testing immediately**
 - Preserve logs/notes of last actions
 - Notify primary contact within 15 minutes

- Resume only after explicit approval

Logging & Monitoring Expectations

- ACME may monitor/record tester activity for defensive verification
- ACME to provide (if possible): SIEM alerting contact and a process to distinguish test activity from real incidents

Data Handling & GDPR (retention/deletion)

- Data minimization: only collect evidence necessary to prove findings
- Avoid collecting patient records; if encountered, capture redacted screenshots/snippets only
- Storage: encrypted at rest, access limited to test team
- Retention: retain evidence for **X days** (e.g., 30 days) after final report delivery, then securely delete
- Secure deletion confirmation provided to Compliance Officer upon request

Deliverables & Reporting

- Scoping report (this document) + final penetration test report
- Findings list with severity, evidence, and remediation
- Executive summary suitable for non-technical stakeholders
- Debrief meeting

Worksheet C — Methodology Selection & Justification

Chosen methodology

Why appropriate for ACME objectives/constraints

How each relevant phase will be executed

Expected outputs/deliverables from each phase

Chosen methodology

PTES (Penetration Testing Execution Standard) with **OWASP WSTG** mapping for the patient portal testing.

Why appropriate for ACME objectives/constraints

- **PTES** provides a clear pre-engagement and reporting structure suitable for audit preparation and stakeholder communication.
- Supports mixed engagement type: external + limited internal.
- **OWASP WSTG** adds depth for the web application (patient portal) where sensitive data is processed.
- Works well with constraints: emphasizes planning, safe execution, and controlled exploitation.

How each relevant phase will be executed

1. Pre-engagement Interactions

- Confirm scope, windows, approvals, contacts, and data handling
- Confirm test accounts and whitelisting requirements

2. Intelligence Gathering

- Enumerate `203.0.113.10/.20/.30` using safe scans, banner grabbing, TLS review
- Identify exposed services and versions

3. Threat Modeling

- Identify key threats: patient data exposure, account takeover, VPN compromise, email compromise, AD privilege escalation

4. Vulnerability Analysis

- Map discovered services to known weaknesses; validate safely
- For web portal: test OWASP categories (auth/session, access control, injection, config)

5. Exploitation

- Only controlled exploitation to prove impact (e.g., limited PoC)
- Avoid actions that risk downtime or data loss

6. Post-Exploitation

- Limited: demonstrate potential impact (privilege level, accessible data) without persistence
- For internal: demonstrate AD misconfig impact (e.g., privilege escalation paths) without broad lateral movement

7. Reporting

- Document evidence, risk ratings, remediation steps, and retest guidance

Expected outputs/deliverables from each phase

- Pre-engagement: signed RoE, confirmed scope, schedule
- Intel gathering: asset/service inventory
- Threat modeling: prioritized attack paths
- Vulnerability analysis: validated findings list
- Exploitation/post-exploitation: impact evidence and risk narrative
- Reporting: executive summary + technical appendix + remediation plan

Worksheet D — Mini Scoping Report

Executive Summary
Objectives & Scope (in/out)
Rules of Engagement (key points)
Methodology Overview & Rationale
Risks & Constraints
Deliverables & Acceptance Criteria
Approvals Required

Executive Summary

ACME Health Systems requires an external penetration test with a limited internal component to prepare for an upcoming audit. ACME processes sensitive personal data and is subject to GDPR. This engagement is designed to identify and safely validate security weaknesses affecting Internet-facing services (patient portal web server, VPN gateway, mail server) and core internal services (Active Directory and file server). Testing will be conducted with strict non-disruption constraints and defined data-handling controls.

Objectives & Scope (in/out)

Objectives

- Identify vulnerabilities that could lead to unauthorized access, data exposure, or audit findings
- Validate exploitability safely and provide remediation guidance
- Provide evidence-based reporting aligned to business risk and GDPR considerations

In Scope

- External: 203.0.113.10 (Web), 203.0.113.20 (VPN), 203.0.113.30 (Mail)
- Limited internal: Active Directory and File Server (credentialed checks preferred)
- Enumeration and safe vulnerability validation

Out of Scope

- DoS/stress testing and any activity likely to disrupt services
- Social engineering and physical security testing
- Third-party SaaS systems
- Database stress testing / availability-impacting validation

Rules of Engagement (key points)

- Testing permitted primarily outside business hours (18:00–08:00 weekdays; weekends if approved)
- CEO approval required prior to start
- Immediate stop-and-notify procedure if degradation occurs
- GDPR-aligned data minimization, encrypted storage, defined retention and deletion

Methodology Overview & Rationale

PTES will be used to structure the engagement from pre-engagement through reporting, ensuring traceability and audit-ready documentation. OWASP WSTG will guide patient portal web testing to ensure coverage of common and high-impact web risks relevant to sensitive data processing.

Risks & Constraints

- Availability sensitivity: no disruption Monday–Friday 08:00–18:00
- Risk of scanner-induced instability: use rate limits and safe profiles
- GDPR exposure risk: avoid collecting patient data; redact evidence
- Change management: notify ACME before any potentially risky validation steps

Deliverables & Acceptance Criteria

Deliverables

- Final report including:
 - Executive summary
 - Scope confirmation and methodology
 - Findings with severity, evidence, and remediation
 - Constraints/assumptions and limitations

Acceptance Criteria

- Scope clearly defined and adhered to
- No unapproved disruptive testing
- Findings are reproducible, evidenced, and prioritized
- Data handling meets GDPR minimization and retention/deletion requirements

Approvals Required

- Written authorization signed by **Marissa Henley (CEO)**
- Operational sign-off and scheduling confirmation by **Sarah Whitaker (IT Manager)**
- GDPR/data handling acknowledgement by **Daniel Chu (Compliance Officer)**